星河虚拟银行 Agent

安全自评报告

加固版 · 权限分级实现说明 · 加固措施与复测证据 · 残余风险清单

测评对象	星河虚拟银行 Agent（Agent-API 智能版 → 安全加固版 20261101）
报告类型	自评估（Self-Assessment），非第三方认证
本轮工作	处置首轮 18 条发现，逐项加固并复测，更新权限分级与残余风险
测评方式	代码级复核 + 162 项自动化回归 + 29 项 HTTP 黑盒探测 + 攻击路径复测
处置结果	已修复 14 项、部分修复 4 项
报告版本	V2.0（替代 V1.0）
编制日期	2026-11-01
密级	公开（参赛材料）

本报告的测评对象是本地合成数据的教学原型。全部结论只适用于当前代码基线，不构成生产系统安全认证、合规结论或对外部服务的评价。

摘要

首轮自评估（V1.0）给出 18 条发现，其中 1 条严重、2 条高。本轮按发现逐项加固，并在加固后重新执行全量回归与黑盒探测。本报告取代 V1.0，给出处置结果、复测证据与仍然存在的风险。

0.1 总体结论

加固后的系统在“演示原型”这一定位上已经补齐了最关键的两处信任缺口：认证不再由一句聊天文本决定，资金类操作（含虚构股票买入）不再存在免确认路径。首轮报告中“认证可自证”“确认可旁路”两个生产阻断项均已关闭。

目前仍不具备的能力，全部属于“需要真实基础设施”的类别：真实身份与 MFA、数据库级事务与权威账户存储、KMS/HSM 与外部锚定、跨进程锁，以及尚未做的压测与容量验证。这些不是代码风格问题，而是本机演示无法自证的边界，本报告在第 6 章逐条列出，并在第 7 章给出上生产路线图。

0.2 处置结果

表 1 发现处置统计

级别	首轮数量	已修复	部分修复	当前最高风险
严重	1	1	0	无
高	2	2	0	无
中	10	7	3	审计密钥仍非托管
低	5	4	1	CI 未固定 action SHA
合计	18	14	4	—

统计口径：把“代码中已经没有该缺陷”记为已修复；把“主路径已收紧、但演示环境无法提供完整保障”记为部分修复。“部分修复”集中在审计密钥托管、跨进程锁、姓名脱敏与 CI 固定 SHA——它们都需要演示环境之外的基础设施。

0.3 关键复测数据

表 2 加固前后对比

项目	加固前	加固后	结论
自动化回归	148 项，141 通过 / 7 失败	**162 项，162 通过 / 0 失败**	新增 14 项加固用例，日期漂移一并解决
HTTP 黑盒探测	46 项，45 通过 / 1 缺陷	**29 项，29 通过 / 0 缺陷**	全部符合预期
“切换到 APP”提权	成功提权并扣款	认证不变，扣款被拦	已关闭
股票买入免确认	直接扣款 1 281.28 元	停在待确认，未扣款	已关闭
跨会话绕限额	3×9 000=27 000 全部成功	第三次被限额拦截	已关闭
1.005 元精度	预览 1.01 / 实扣 1.005	入口量化为 1.01，两者一致	已关闭

0.4 给读者的三句话

(1) **先看第 5 章的复测证据：**每条结论都对应可重跑的命令与输出，不看结论也可以自己验一遍。

(2) **再看第 6 章的残余风险：**加固不是把风险清零，而是把“能自己修的”修掉，把“必须有基础设施的”说清楚。

(3) **最后看第 3 章的权限分级：**这是评审最关心、也最容易被含糊描述的部分，本报告给出代码位置与判定公式。

目 录

摘要 3

0.1 总体结论 • 0.2 处置结果 • 0.3 关键复测数据 • 0.4 给读者的三句话

1 测评概述 6

1.1 对象与基线 • 1.2 本轮测评范围 • 1.3 测评方法 • 1.4 环境与限制

2 资产与威胁模型 8

2.1 资产与分级 • 2.2 威胁与处置对照

3 权限分级实现说明 9

3.1 四维控制模型 • 3.2 认证强度分级与一次性安全码 • 3.3 风险分级与下限 • 3.4 操作 × 渠道权限矩阵 • 3.5 授权机制与两类例外 • 3.6 任务归属与会话隔离 • 3.7 人工审核能力现状 • 3.8 权限分级符合性小结

4 加固措施与控制项测评 14

4.1 认证：从“自称渠道”到“一次性凭据”（SEC-01） • 4.2 授权：取消股票免确认路径（SEC-02） • 4.3 限额：进程级共享账本（SEC-03） • 4.4 金额：入口量化 + 严格解析（SEC-04、SEC-13） • 4.5 确认凭据：一次性 nonce（SEC-05） • 4.6 可用性与抗滥用（SEC-06、SEC-09、SEC-10） • 4.7 审计：事件级签名（SEC-07、SEC-08） • 4.8 隐私与脱敏（SEC-11） • 4.9 模型出网收口（SEC-12） • 4.10 工程与可诊断性（SEC-14—SEC-18）

5 复测与验证 18

5.1 自动化回归 • 5.2 HTTP 黑盒探测 • 5.3 首轮攻击路径复测 • 5.4 交付完整性

6 残余风险清单 20

7 上生产路线图 21

7.1 五个阶段性任务 • 7.2 复测要求

8 测评结论 22

8.1 结论 • 8.2 控制有效性评价 • 8.3 声明 • 8.4 签署

附录 A 证据索引 24

附录 B HTTP 黑盒探测结果 25

1 测评概述

1.1 对象与基线

对象为“星河虚拟银行 Agent”安全加固版（2026-11-01），代码基线继承自 2026-10-29 的 Agent-API 智能版。加固后 `banking_agent/` 下共 15 个 Python 文件、5 662 行代码，测试 10 个模块、162 个用例。所有测评在项目目录之外的可写副本中执行，被测代码保持只读。

1.2 本轮测评范围

表 3 测评范围

范围	内容	覆盖
首轮 18 条发现的处置验证	逐条检查代码是否已改、行为是否如预期	覆盖
权限分级	认证、风险、授权、归属四维的实现与边界	覆盖
HTTP 边界	回环、Host/Origin、CSRF、体积、白名单、响应头、方法	覆盖
会话与可用性	会话上限与淘汰、读超时、并发上限、状态增长	覆盖
审计与隐私	事件签名、链校验、短码脱敏、密钥保管	覆盖
模型接入	地址收口、密钥不落盘、响应校验、工具白名单	覆盖
金额与业务逻辑	量化、精度、非法表达式、限额口径	覆盖
未覆盖	真实身份/MFA、数据库事务、KMS、跨进程锁、压测与容量、第三方渗透测试	不覆盖（见第 6 章）

1.3 测评方法

表 4 测评方法

方法	做法	产出
代码复核	逐个检查 18 条发现的修改点，确认没有引入新的绕过路径	处置状态与行号证据

方法	做法	产出
自动化回归	执行 162 项用例，含新增 14 项加固用例	通过/失败统计
HTTP 黑盒探测	启动真实服务，构造 29 组请求验证认证、确认、限额、会话与响应头	逐项实测（附录 B）
攻击路径复测	按首轮报告的攻击路径重放，对比加固前后现象	前后对照（表 2、表 19）
交付完整性	核对源文件与打包清单	文件清单与哈希

1.4 环境与限制

环境为 Windows 11 x64 + 项目内置 CPython 3.13.17。演示业务日期固定为 2026-10-29（`DEMO_TODAY`），审计事件时间戳仍使用真实 UTC 时间。

本次仍为**自评估**：未做真实网络渗透、自动化浏览器扫描、模糊测试与容量压测；未评估模型供应商侧安全；所有结论只对当前代码基线与本机演示形态有效。

2 资产与威胁模型

2.1 资产与分级

表 5 资产与保护

资产	位置	分级	加固后的保护
账户余额、流水、持仓	会话内存 `SimulatedBank`	内部（合成）	会话身份绑定 + 认证门
确认摘要与 nonce	Agent 任务内存	敏感	一次性 nonce，用后作废
演示安全码	服务端 `AuthChallenge`	敏感（演示）	5 分钟有效、用后轮换、仅本机会话可见
会话 Cookie / CSRF	浏览器 + 服务端	敏感	HttpOnly + SameSite=Strict + Max-Age
模型 API Key	进程内存 `APIConfig`	机密	不落盘、不回显、响应回显擦除
审计文件	`data/web-*.jsonl`	内部（证据）	哈希链 + 事件 HMAC 签名
日累计限额	进程级 `TransferLedger`	内部	跨会话共享，不能靠新会话重置

2.2 威胁与处置对照

表 6 威胁与处置

威胁（STRIDE）	首轮形态	加固后	结论
仿冒	任意访问者自动成为演示用户；对话文本可提升认证	会话身份绑定 + 一次性安全码；文本不再影响认证	显著改善（真实身份仍缺）
篡改	改审计文件、重算哈希链	事件 HMAC 签名；无密钥无法重算	改善（无外部锚定）
否认	不记录原话，会话标识共用	每会话独立标识；仍不记录原话	部分改善
信息泄露	6 位验证码、姓名不脱敏	关键词邻域遮罩；姓名按展示需要保留	改善
拒绝服务	占满 30 会话永久 503；慢连接占线程	LRU 淘汰 + 空闲回收 + 读超时 + 并发上限	显著改善
权限提升	一句话提权；股票免确认	两处均已关闭	已关闭

3 权限分级实现说明

权限分级是本项目最容易被误读的部分。本章给出加固后的实现：每个维度都由服务端状态决定，客户端能改变的只有“发起哪个请求”，不能改变“自己处于哪一级”。

3.1 四维控制模型



图 1 四维权限控制模型

表 7 四维控制模型

维度	判断的问题	代码表示	加固点
认证强度	当前会话是否达到该操作要求的等级	`AuthLevel` / `AuthResult`	渠道来自服务端；升级需一次性安全码
操作风险	这项操作需要何种流程，是否必须审核	`RiskLevel` / `effective_risk`	只升不降；R4 不执行
用户授权	用户是否授权了当前内容	摘要 + 一次性 nonce + 范围授权	nonce 不可推导、不可重放
任务归属	请求是否属于当前会话的任务	`user_id + session_id + task_id`	会话标识按会话独立

3.2 认证强度分级与一次性安全码

表 8 认证等级

等级	数值	来源	当前实现
NONE	0	渠道 other	无账户操作认证
STANDARD	1	渠道 im	普通查询可执行，资金操作被拦
ENHANCED	2	渠道 app	变更类操作的最低要求
MANUAL	3	—	保留枚举，**没有任何流程要求本级，也不代表已实现审核员登录**

```
# demo.py：渠道由服务端提供，而不是请求参数
def authenticate(self, user_id, session_id, required_level, channel="app"):
    identity = self._identity or ("demo-user", "demo-session")
    ok = (user_id, session_id) == identity
    effective = self._channel_source() if self._channel_source is not None else channel
    channel_levels = {"app": ENHANCED, "im": STANDARD, "other": NONE}
    level = channel_levels.get(effective, NONE) if ok else NONE
    return AuthResult(ok and level >= required_level, level)

# demo.py：一次性演示安全码
class AuthChallenge:
    def rotate(self):  self.code = 6 位随机数; self.expires_at = now + 300s
    def verify(self, code):
        if 已过期 or not compare_digest(code, self.code): return False
        self.rotate(); return True
```

网页侧的升级路径只有一条：`POST /api/message {action:'authenticate', factor:'123456'}`，校验通过后把服务端渠道置为 `app`，并写入 `auth_strengthened` 审计事件。命令行等价于发送“认证 123456”。

这条设计解决了什么、没解决什么

解决了：认证等级不再能被一句聊天文本改变，也不能被伪造的请求参数改变；每次升级都有一次性凭据与审计痕迹。没解决：页面本身会显示这个码，因此它证明“有人在操作这个会话”，不证明“这个人是谁”。真实身份仍需登录、MFA 与会话吊销，见第 6 章 R-01。

3.3 风险分级与下限

表 9 风险等级与处理

等级	操作下限（示例）	核心处理	是否可能自动执行
R0	公共规则说明	公开工具，不查账户	不涉及资金
R1	余额、流水、账单、持仓查询	≥ STANDARD 后查询	不涉及资金
R2	分类纠正、预算、提醒、临时锁卡、创建计划	≥ ENHANCED，摘要确认	否
R3	转账、AA、投资（含股票）、卡片与订阅变更	≥ ENHANCED，先确认	仅小额直转与计划范围两类例外
R4	诈骗/胁迫、限额触发、首次收款人、适当性未过	暂停，只进审核队列	**否**

合并规则未变：`level = max(minimum_risk(operation), tool_assessment.level)`，`manual_review_required` 强制 R4，转账金额触发阈值只升不降。加固点在于：**投资类操作不再有免确认路径**。

3.4 操作 × 渠道权限矩阵

表 10 操作 × 渠道矩阵

操作	`other` / NONE	`im` / STANDARD	`app` / ENHANCED
公开说明类查询	允许	允许	允许
普通账户查询（R1/R2）	等待认证	允许	允许
敏感账户查询（R3）	等待认证	等待增强认证	允许
R4 查询	不返回数据	须先增强认证	转审核，不返回结果
任意变更（含锁卡、预算、股票）	等待增强认证	等待增强认证	预览 → 确认 → 执行
新收款人首次转账	等待增强认证	等待增强认证	先核对虚构收款人，再按金额/风险继续
网页小额即时转账（< 3 000）	不执行	不执行	满足全部例外条件可执行
虚构股票买入	不执行	不执行	预览 + 用户确认后执行
R4 变更	不执行	不执行	确认后进审核，仍不执行

3.5 授权机制与两类例外

表 11 授权路径

授权路径	触发条件	边界	审计记录
显式确认	用户输入确认短语且一次性 nonce 匹配	摘要变化 → 重新确认；过期 → 失败；nonce 用后作废	`confirmation_received`（received=true）
网页小额直转	`0 < 金额 < 3000`、CNY、零费用、单次、立即、非 R4、已解析收款人、两次预览一致	严格小于 3 000；小数位 ≤ 2；摘要变化即退回确认	`configured_transfer_authorization_used`（received=false）
计划范围授权	计划已确认建立；商户/商品/预算/次数/有效期全部在界内	任一项越界即拒绝；新风险信号升级 R4	`scope_authorization_used` + 逐笔订单事件

加固后不再有第三条“股票一键买入”例外：该操作现在与转账一样，必须先生成服务端预览、再由用户点击确认。这也让“所有 R3 及以上变更都要确认”从一句描述变成了可检查的性质。

3.6 任务归属与会话隔离

每个网页会话生成独立标识 `web-<随机>`，`SimulatedBank.bind_identity()` 之后只接受这一组 `(user_id, session_id)`；`_owned_task()` 仍要求 `user_id + session_id + task_id` 三者同时匹配。审计事件里的 `session_id_hash` 因此可以区分会话。余额与业务数据仍按会话隔离（教学沙盒），但**当日转账累计限额改为进程级共享**，避免多开标签页绕过限额。

3.7 人工审核能力现状

R4 请求在确认后进入 `ManualReviewTool.submit()`，`accepted=True` 表示**队列受理**，不是审核通过。系统只记录 `pending` / `cancelled` / `declined`，没有“批准后自动执行”的分支，也没有管理员表、角色分配、双人复核或审核员工作台。因此本报告不把 R4 称作“管理员权限”。

3.8 权限分级符合性小结

表 12 权限分级符合性

控制目标	加固后实现	结论
不同敏感度要求不同认证强度	查询 STANDARD / 变更 ENHANCED / R3 查询升 ENHANCED	符合
认证结果不可由调用方伪造	渠道来自服务端状态；升级需一次性安全码；会话身份绑定	符合（演示级）
高风险操作必须审核且不自动执行	R4 只排队/取消/拒绝	符合
资金变更必须获得明确授权	所有 R3+ 变更均需确认；仅保留两条例外	符合
授权内容与执行内容一致	入口量化金额；nonce + 摘要双重绑定	符合
任务与数据按主体隔离	会话独立标识与对象；限额跨会话共享	符合
权限判断可审计	认证、风险、确认、执行均有事件；事件带签名	符合
最小权限 / 默认拒绝	配置缺失、工具缺失、审计不可用一律失败关闭	符合

4 加固措施与控制项测评

本章按首轮发现的顺序说明“改了什么、为什么这样改、怎么验证”。每条都给出代码位置与复测现象。

4.1 认证：从“自称渠道”到“一次性凭据”（SEC-01）

修改：删除 `DemoConversation` 中“切换到 APP”直接改 `self.channel` 的分支；新增 `AuthChallenge`；`SimulatedBank.authenticate()` 通过 `bind_channel_source()` 读取服务端渠道；新增 `bind_identity()`。网页新增 `action=authenticate` 与页面「安全认证」入口。

表 13 认证加固

项	加固前	加固后
升级方式	聊天发送“切换到 APP”	输入页面显示的 6 位一次性安全码
凭据	无	`secrets` 生成、5 分钟有效、用后轮换
判定来源	`OperationRequest.channel`（可伪造）	服务端会话状态（不可由请求改变）
审计	`channel_changed`	`auth_strengthened` + `channel_changed`

复测：IM 下转账 → `AWAITING_AUTHENTICATION`；发送“切换到 APP” → 认证仍为 IM，任务不恢复；输入正确安全码 → 认证升至 APP，任务恢复为 `SUCCESS` 且此前未扣款；同一安全码再次使用 → 400。

4.2 授权：取消股票免确认路径（SEC-02）

修改：`agent._create_preview()` 的范围授权分支只允许 `CROSS_SCENARIO`；`SimulatedBank.is_pre_authorized()` 删除 `INVESTMENT/buy_stock` 分支。前端按钮文案改为“买入 …（需确认）”。

复测：“买入 XH001 100 股” → `AWAITING_CONFIRMATION`，余额 50 000.00 不变；点击“确认投资操作” → `SUCCESS`，扣款 1 281.28 元；重复确认不再扣款。

4.3 限额：进程级共享账本（SEC-03）

修改：新增 `TransferLedger`，以（业务日，账户尾号）为键累计；`LocalBankServer` 创建一个实例并注入每个会话的 `SimulatedBank.ledger`；`_daily_transfer_total()` 优先读账本。

复测：单个会话转 9 000 元成功；第二个会话再转 9 000 元成功（合计 18 000）；第三个会话请求 9 000 元时升级为 R4/限额拦截。余额仍按会话隔离，这是教学沙盒的设计选择，已在文档中明确。

4.4 金额：入口量化 + 严格解析（SEC-04、SEC-13）

修改：`BankingAgent._normalize_amounts()` 在 `submit()` 与 `provide_information()` 入口把金额量化到分并回写 payload；`DemoConversation._extract_amount()` 改为严格整串匹配，拒绝科学计数法、千分位、全角数字与三位以上小数。

表 14 金额处理对比

输入	加固前	加固后
1.005 元（结构化）	预览 1.01、实扣 1.005	入口即 1.01，预览与实扣一致
1.005 元（文本）	同上	直接拒绝，要求两位小数
1e999 元	截取为 999 元并执行	拒绝：金额格式无法识别
1,000,000 元	截取为 000，最终失败	拒绝：金额格式无法识别
１００元（全角）	后续转换失败	拒绝：请使用半角数字

4.5 确认凭据：一次性 nonce（SEC-05）

修改：`BrowserSession.confirmation_token()` 改为从任务内部计划读取/生成 `secrets.token_urlsafe(24)`；确认请求通过校验后立即从任务中删除该 nonce，服务端不再用 `sha256(csrf + 摘要)` 推导。

复测：确认前快照返回 32 字符随机串；确认成功后快照不再返回 nonce；用同一 nonce 再次提交不产生二次扣款。

4.6 可用性与抗滥用（SEC-06、SEC-09、SEC-10）

表 15 可用性加固

控制	加固前	加固后
会话上限	满 30 后永久 503，需重启	LRU 淘汰 + 30 分钟空闲回收；实测 34 次建会话全部 200，服务端保持 ≤ 30
Cookie 有效期	无 Max-Age	`Max-Age=28800`
请求头读超时	读完头后才设超时	`LocalBankHandler.timeout = 10`
并发处理	每连接一线程、无上限	`BoundedSemaphore(24)`，超限直接 503 并关闭
会话状态	`messages/requests` 无界增长	保留最近 60 条消息、最近 2 000 个请求编号

4.7 审计：事件级签名（SEC-07、SEC-08）

修改：`AuditLog.append()` 在 `event_hash` 之后追加 `event_mac = HMAC-SHA-256(key, event_hash)`；`verify()` 在链校验之后逐条校验签名，签名不符即抛 `AuditError`。

边界：密钥仍来自源码或环境变量，没有 KMS/HSM，也没有外部锚定；签名把“悄悄改一行”的成本提高，但不能阻止拥有密钥的人重算整条链。跨进程锁仍未实现（单进程演示）。

4.8 隐私与脱敏（SEC-11）

修改：`privacy.redact_text()` 增加关键词邻域遮罩：验证码/校验码/动态码/短信码/口令/密码/安全码之后的 4—8 位数字统一替换为 `••••`，再执行原有的长数字串遮罩；日期格式保持原样。

边界：姓名与金额仍需展示给用户，不做遮罩；自由聊天原文仍保存在本人会话内存中，审计不落原文。

4.9 模型出网收口（SEC-12）

修改：`APIConfig.__post_init__()` 增加地址判定：只允许公网地址或本机回环；拒绝 RFC1918/保留/链路本地地址，以及 `.local`、`.internal`、`.lan`、`.corp`、`.intranet` 等内部域名。

复测：`https://10.0.0.5/v1`、`https://192.168.1.2/v1`、`https://model.internal/v1`、`http://169.254.169.254/latest` 全部被拒；`https://api.example.com/v1` 与 `http://127.0.0.1:8080/v1` 可用。

4.10 工程与可诊断性（SEC-14—SEC-18）

表 16 工程项处置

编号	加固前	加固后
SEC-14	响应含 `Python/3.13.17`；HEAD/PUT 返回 501 HTML	`server_version` 固定为 `XingheBankDemo`；非支持方法统一 405 JSON；补 `Permissions-Policy`
SEC-15	所有异常折叠为 `operation_not_completed`	区分 `policy_rejected` / `tool_validation_failed`，并把中文原因回显给用户
SEC-16	所有会话共用 `demo-user/demo-session`	每会话独立 `web-<随机>` 标识参与认证与审计
SEC-17	测试硬编码 `2026-11-01`，到期即红	演示业务日期固定 `DEMO_TODAY=2026-10-29`，回归可复现
SEC-18	CI action 用浮动标签、无扫描	**未修复**：仍需在联网环境固定 commit SHA 并启用 secret scanning

5 复测与验证

5.1 自动化回归

在 Windows x64 + 内置 CPython 3.13 环境下执行 `python -X utf8 -m unittest discover -s tests -v`：**162 项全部通过**（失败 0、错误 0、跳过 0）。新增的 `tests/test_hardening.py` 覆盖认证不可自证、安全码一次性与时效、股票确认门、金额量化与非法金额、共享限额账本、短码脱敏、内网地址拒绝、审计签名、会话淘汰与确认 nonce。

表 17 回归结果

模块	用例	本次结果
`test_hardening`（新增）	14	全部通过
`test_agent` / `test_demo` / `test_web`	60	全部通过（日期相关用例因固定业务日期恢复通过）
`test_recipients` / `test_stocks`	20	全部通过（股票用例已改为“预览 + 确认”）
`test_llm_agent` / `test_llm_client` / `test_web_llm`	64	全部通过
`test_launcher`	4	全部通过
合计	162	162 通过

5.2 HTTP 黑盒探测

启动真实服务后构造 29 组请求，**29 项全部符合预期**。完整结果见附录 B，关键项：

表 18 探测摘要

类别	用例	结果
认证升级	IM 转账被拦；“切换到 APP”不提权；错误/过期/重放安全码	全部符合
股票确认	买入停在待确认；确认后成交；重放不二次扣款	全部符合
金额边界	1.005 / 1e999 / 1,000,000 / 全角数字	文本渠道全部拒绝且不扣款
跨会话限额	两个会话各 9 000 后第三个 9 000	被限额拦截
会话与并发	连续 34 次建会话；3 路并发同 request_id	无 503；仅扣款一次

类别	用例	结果
响应头与方法	Python 版本隐藏、Permissions-Policy、PUT → 405	全部符合

5.3 首轮攻击路径复测

表 19 攻击路径复测

首轮路径	加固前现象	加固后现象
“切换到 IM”→转账→“切换到 APP”	认证升至 ENHANCED，扣款 25 元	认证不变，任务停在 AWAITING_AUTHENTICATION
`buy_stock XH001 100 股`	SUCCESS，扣 1 281.28 元	AWAITING_CONFIRMATION，余额不变
3 个会话各转 9 000 元	三次全部 SUCCESS，合计 27 000	第三次被限额拦截
payload `amount=1.005`	预览 1.01、实扣 1.005	入口量化为 1.01，两者一致
“转账 1e999 元”	执行 999 元直转	拒绝，余额不变
连续 31 次 `GET /api/state`	新会话永久 503	全部 200，服务端会话保持 ≤ 30
改写审计文件一行	哈希链不匹配（但可整链重算）	签名不匹配；无密钥无法重算

5.4 交付完整性

源码包与交付清单保持一致：15 个业务模块、10 个测试模块、前端静态资源与文档均可按清单核对；新增文件为 `tests/test_hardening.py`。演示业务日期固定后，样例数据与验收脚本不再随真实日期漂移。

6 残余风险清单

下列风险在本次加固后**仍然存在**。它们要么需要真实基础设施，要么属于演示定位的自觉取舍，不应被“已加固”掩盖。

表 20 残余风险

编号	残余风险	为什么还在	影响	建议
R-01	没有真实身份与 MFA；演示安全码在页面上可见	本机演示无法提供真实身份源	无法证明操作人是谁	接入真实登录、MFA、会话吊销与设备绑定
R-02	余额与账户数据仍是每会话沙盒	教学需要每个会话独立可重置	余额不是账户级事实	生产用数据库 + 事务 + 唯一约束
R-03	审计密钥非托管，无外部锚定或 WORM	演示不引入 KMS 与日志服务	有密钥者可重算整链	KMS/HSM 签名 + 外部锚定 + WORM 存储
R-04	审计仅单进程内加锁	演示为单进程	多进程写同一文件会破坏链	独立日志服务或跨进程锁
R-05	不记录用户原话	避免把自由文本写入审计带来隐私风险	事后无法复原“用户怎么说的”	脱敏后的原话摘要 + 长度哈希
R-06	姓名、金额不脱敏	界面必须展示	截图可能泄露	对外场景启用更严格的展示策略
R-07	无压测、无容量与故障注入	超出演示范围	生产行为未知	上线前做容量、故障与混沌测试
R-08	CI action 未固定 SHA，无依赖/秘密扫描	本次未联网配置	供应链信任依赖上游	固定 commit SHA + Dependabot + secret scanning
R-09	模型返回内容仍可能包含误导性表述	模型本身不可控	用户可能被错误解释影响	解释层固定模板 + 结果以系统回执为准

风险编号 R-01..R-09 取代首轮 SEC-01..SEC-18：已关闭的发现不再列出，仍在的按残余风险重新编号，便于后续复测时逐条勾选。

7 上生产路线图

7.1 五个阶段性任务

表 21 路线图

优先级	任务	内容	验收标准
P0	真实身份与会话	接入银行身份服务、MFA、会话吊销与设备绑定；渠道与认证等级全部由服务端可信上下文推导	无凭据无法获得 ENHANCED；对话与请求参数无法改变认证
P0	权威账户存储	余额、限额、收款人、幂等记录入数据库；限额在账户维度加锁；会话只存意图与凭据	跨会话、跨进程累计一致；并发扣款不出错
P1	审计可信化	事件签名接入 KMS/HSM；外部锚定或 WORM；运行期持续校验；跨进程锁；记录脱敏原话摘要	无密钥无法伪造；篡改在运行期被发现
P1	容量与可用性	压测、限流、连接池、故障注入；补齐监控与告警	定义并验证目标 QPS 与错误率
P2	供应链与分发	CI action 固定 SHA、依赖与秘密扫描、分发包签名	构建与分发可验证来源

7.2 复测要求

任何改动认证、确认、限额、审计或出网配置的提交，都必须重新执行：162 项回归 + 29 项 HTTP 探测 + 第 5.3 节的 7 条攻击路径复测，并在报告中更新处置状态。复测结果需记录环境、命令与通过/失败数量，不使用旧截图代替。

8 测评结论

8.1 结论

作为本地教学演示原型，加固后的系统已经具备自洽的安全叙事：认证不能靠嘴说、资金不能绕确认、限额不能靠开新窗口重置、审计改一行会被发现。 首轮的两个生产阻断项（认证自证、确认旁路）已经关闭，其余中低风险项大部分完成处置。

作为可上线的金融系统，它仍然不够。 缺的不是零散校验，而是三类基础设施：真实身份、权威账户存储、可信审计设施。这三项都在第 6 章列为残余风险，并在第 7 章给出阶段任务；在本机演示形态下，它们无法通过写代码解决。

8.2 控制有效性评价

表 22 控制有效性对比

维度	加固前	加固后	说明
HTTP 与浏览器边界	A-	A	补 Permissions-Policy、隐藏版本、统一 405
认证	D	B	改为服务端渠道 + 一次性安全码；真实身份仍缺
授权与确认	B-	A-	股票并入确认门；nonce 一次性；金额量化
风险分级与审核	A-	A-	规则未变，实测仍不执行 R4
执行与幂等	A-	A	并发与重放实测符合
审计（对抗性）	C+	B	事件签名；仍无密钥托管与外部锚定
隐私与脱敏	C	B-	短码已遮罩；姓名金额仍展示
可运维 / 抗滥用	C-	B	会话淘汰、读超时、并发上限

8.3 声明

本报告由项目方自行编制，用于参赛材料与内部改进，不构成第三方认证、等保测评或合规结论。报告中的“符合/不符合”仅相对于本报告所列检查框架；不得引用本报告声称系统“已通过安全测评”或“达到生产安全要求”。所有实测数据可复现，代码基线在测评期间未被修改。

8.4 签署

表 23 签署栏

角色	姓名/标识	日期	备注
编制	项目技术负责人	2026-11-01	V2.0 自评估
复核	（待指定）	—	建议由具备安全背景的第三人复核第 6 章
批准	（待指定）	—	对外提交前完成

附录 A 证据索引

表 24 证据索引

主题	证据位置
认证	demo.py：AuthChallenge、bind_identity、bind_channel_source、authenticate；web_app.py：apply_authentication
授权与确认	agent.py：_create_preview、confirm；web_app.py：confirmation_token、send
金额	agent.py：_normalize_amounts；demo.py：_extract_amount、_MALFORMED_AMOUNT
限额	demo.py：TransferLedger、_daily_transfer_total；web_app.py：LocalBankServer.ledger
会话与可用性	web_app.py：LocalBankServer.sweep_sessions、process_request；LocalBankHandler.timeout
审计	audit.py：_mac、append、verify
隐私	privacy.py：_SHORT_CODE、redact_text
模型	llm_client.py：APIConfig.__post_init__
测试	tests/test_hardening.py（14 项）

附录 B HTTP 黑盒探测结果

共 29 项，执行于 `127.0.0.1` 随机端口。判定“符合”表示实测行为与预期一致。

表 25 探测明细

编号	检查项	预期	实测	结论
P01	安全码随会话下发且为 6 位	6 位数字	696832	符合
P02	并发会话拥有独立 CSRF 与安全码	两者均不同	csrf 不同=True	符合
P03	响应头不再泄露 Python 版本	Server 不含 Python 版本号	XingheBankDemo	符合
P04	Permissions-Policy 头存在	存在	True	符合
P05	伪造 Host	403	403	符合
P06	路径穿越	404	404	符合
P07	PUT 方法统一 405 JSON	405	405	符合
P08	聊天文本可降级渠道（无凭据）	降级成功	im	符合
P09	IM 渠道下资金操作被拦	AWAITING_AUTHENTICATION	AWAITING_AUTHENTICATION	符合
P10	一句话“切换到 APP”不再提权	仍为 AWAITING_AUTHENTICATION	AWAITING_AUTHENTICATION，channel=i…	符合
P11	错误安全码被拒	400	400: 演示安全码错误或已过期，认证等级未提升。	符合
P12	正确安全码完成增强认证	channel=app	app	符合
P13	同一安全码不可重放（降级后重试）	400	400	符合
P14	任务在增强认证后恢复	SUCCESS	SUCCESS	符合
P15	IM 期间未发生扣款	50000.00 -> 49975.00	49975.00	符合
P16	股票买入不再直接成交	AWAITING_CONFIRMATION	AWAITING_CONFIRMATION, 余额=50000.00	符合
P17	确认随机串为一次性 nonce（非摘要）	长度 >= 20 且与 code 无关	32 字符	符合
P18	确认后成交	SUCCESS 且扣款 1281.28	SUCCESS, 48718.72	符合
P19	重放确认不再扣款	余额不变	48718.72	符合
P20	文本渠道的三位小数金额被拒绝	不扣款且提示金额格式	余额=50000.00	符合
P21	两位小数金额正常执行	49999.50	49999.50	符合
P22	非法金额 给小明转账 1e999 元	拒绝且不扣款	50000.00	符合
P23	非法金额 给小明转账 1,000,000 元	拒绝且不扣款	50000.00	符合
P24	非法金额 给小明转账 1 0 0 元	拒绝且不扣款	50000.00	符合

编号	检查项	预期	实测	结论
P25	单会话 9000 元成功	SUCCESS	SUCCESS	符合
P26	跨会话累计到 27000 时被限额拦截	第三次进入审核或不执行	单次=SUCCESS, 第三次=AWAITING_CONFIRMAT…	符合
P27	会话上限采用淘汰而非永久拒绝	全部 200 且服务端会话 <= 30	200=34, 503=0, 现存=30	符合
P28	3 路并发同一 request_id	仅扣款一次 100.00	[200, 200, 200], 余额=49900.00	符合
P29	聊天中的 6 位验证码仍按原样保存（设计如此，审计不落原文）	审计中不含 123456	见审计文件核对	符合